

AWS Cloud Security for Government Cloud Migration Applications under COVID-19



CS 696 Summer 2021

Researchers

Christopher Wood

Jinhong Tan

Michael Egemba

YuQing (Eugina) Ding

Best Practices Cloud Security Review and Future Applications for Government Cloud Services

- 1 Government Cloud Migration Overview and Infrastructure Cloud Security
- 2 AWS Identity and Access Management (IAM)
- 3 AWS Database Protection using Snowball Edge
- 4 AWS Threat Detection

Government Agency Security Data Levels

Security clearances can be issued by United States of America government agencies, including the Department of Defense (DoD), the Department of State (DOS), the Department of Homeland Security (DHS), the Department of Energy (DoE), the Department of Justice (DoJ), the National Security Agency (NSA), and the Central Intelligence Agency (CIA) [1] [2].

1. TOP SECRET – critical data for national security.
2. SECRET.
3. CONFIDENTIAL.
4. Restricted (limited to agency internal use).
6. Public Data (public use, such as web service, public records)

Standard Handling Classified Data before COVID-19

Federal/Government employees are personally responsible to safeguard classified data at all times to prevent loss or compromise and unauthorized disclosure, dissemination, or duplication.

Unauthorized disclosure of classified material is punishable under the Federal Criminal Statutes or organizational policies.

Classified material shall not be transmitted through email, taken home, and one must not work on classified material at home.

1. Application Form, Review and Approval
2. Make Appointment to Records Department
3. Registry, Signature, Copy in person.
4. Top Secret/Secret Data subject to continuing accountability



COVID-19 No Remote Data Transfer, Operations Halted



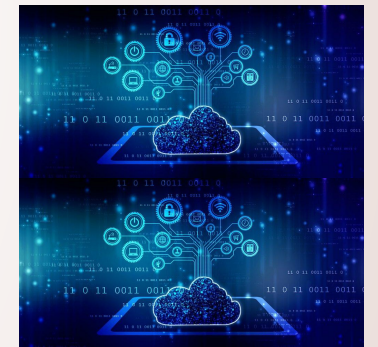
MTA has budget cut of \$4.6B during COVID-19



Migrate Government Operations to Cloud - Security Concerns

Pentagon terminates controversial \$10 billion JEDI cloud contract with Microsoft

The 10-year cloud-computing contract was awarded to Microsoft in October 2019, but a lawsuit filed by AWS claimed that then-President Donald Trump's vendetta against Amazon and CEO Jeff Bezos was a key factor in Microsoft's win.



AWS

Microsoft Azure

Google Cloud

IBM/Big Blue

Others

Major

Cloud

Platforms

Flexible Hybrid Cloud Solution for Government Data & Applications Migration

**REMOTE
ACCESS**

Cloud Service

vs.

C3* Data Center

***C3 Center:
Command,
Control and
Comms
Center**

Elastic, Scalable, Flexible	On Premise Hardened
Public Cloud Computing	Private Cybersecurity, Reliability
Low Operation Cost	Costly Installation and Operation
Low Maintenance Cost	High Maintenance Cost
Latest Technology	Costly Expansion and Update
cores, software based	servers, hardware based
Large Amount of Less Confidential, Historical, Archiving, Public Data	Core Data Only: Top Secret/Secret, Critical, Confidential

AWS Cloud Security Services

Worldwide public cloud services market will grow 17.5% in 2019 to total \$214.3 billion in 2022. [4] [5]



Infrastructure Protection



Identity and Access Management (IAM)



Database Protection



Threat Protection and Continuous Monitoring

12.6%

Cloud Services
will grow to
\$331 BILLION
in 2022

- Gartner Research

AWS Infrastructure Protection

- **AWS Protected Network VPC**
- **AWS Shield**
- **AWS Firewall Manager**
- **AWS Web Application Firewall**



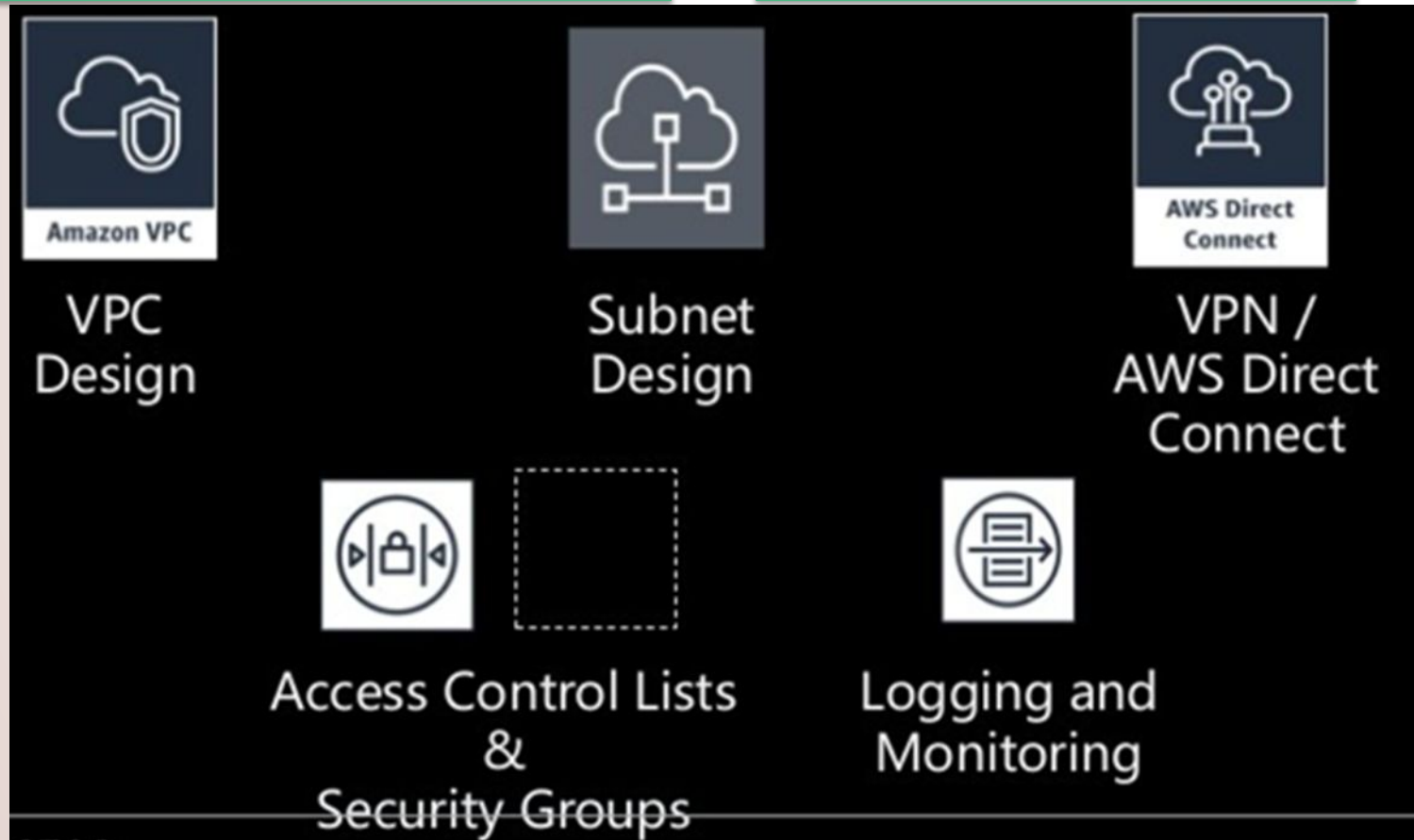


C3 Center Applications



Remote Employees

AWS Infrastructure Protection – Overview



* AWS Protected VPC for Each Agency for High Security



AWS Infrastructure Network Protection

Configuration Details of Protected Network and Host Level for High Security

VPC considerations:

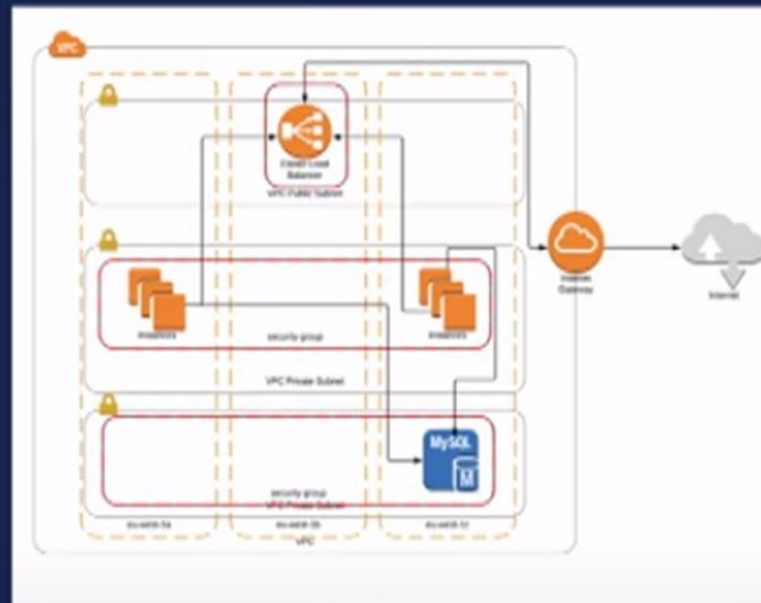
- Subnets to separate workloads
- Use NACLs to prevent access between subnets
- Use route tables to deny internet access from protected subnets
- Use Security groups to grant access to and from other security groups

Limit what you run in public subnets:

- ELBs, ALBs and NLBs
- Bastion hosts
- Try and avoid where possible having a system directly accessible from the internet

External connectivity for management:

- Use VPN gateways to your on premise systems
- Direct Connect



Source:
AWS Summit [7]
[8]

AWS Shield

[7] [8]

managed DDoS (distributed denial-of-service) protections
service to safeguard applications running on AWS

AWS Shield API

```
$ aws shield list-attacks
{
  "NextToken": "xxx=",
  "AttackSummaries": [
    {
      "EndTime": 1534529765.0,
      "ResourceArn": "arn:aws:ec2:us-west-2:671090893150:eip-allocation/eipalloc-9a7556a6",
      "AttackId": "c04ab40d-a8e4-47c8-a132-ccccff3a22dd",
      "AttackVectors": [
        {
          "VectorType": "UDP_TRAFFIC"
        }
      ],
      "StartTime": 1534529460.0
    },
    ...
  ]
}
```

```
$ aws shield describe-attack --attack-id c04ab40d-a8e4-47c8-a132-ccccff3a22dd
{
  "Attack": {
    "Mitigations": ["us-west-2_20180817181136833_3925"],
    "ResourceArn": "arn:aws:ec2:us-west-2:671090893150:eip-allocation/eipalloc-9a7556a6",
    "AttackId": "c04ab40d-a8e4-47c8-a132-ccccff3a22dd",
    "SubResources": [
      {
        "Type": "IP",
        "Id": "1.2.3.4",
        "AttackVectors": [
          {
            "VectorCounters": [
              {
                "Name": "NA",
                "Max": 5000000000.0,
                "Average": 5000000000.0,
                "N": 5,
                "Sum": 25000000000.0,
                "Unit": "BPS"
              }
            ],
            "VectorType": "UDP_TRAFFIC"
          }
        ]
      }
    ],
    "StartTime": 1534529460.0,
    "EndTime": 1534529765.0
  }
}
```

Source:
AWS Summit [7]
[8]

AWS Firewall Manager & Web Application Firewall

- Firewall Manager to centrally configure and manage firewall rules for agency's accounts and applications.
- Web Application Firewall (WAF) to protect web applications

AWS WAF API

```
$ aws shield list-web-acls
{
  "WebACLs": [
    {
      "WebACLId": "4881aa42-de4a-4b6d-9792-63fc34a72946",
      "Name": "gokuHealthCheck"
    },
    ...
  ]
}
```

```
$ aws waf list-rules
{
  "Rules": [
    {
      "Name": "blockHealthyUri",
      "RuleId": "fec390cb-95f3-40cc-9549-5e85f1894f7f"
    },
    ...
  ]
}
```

```
$ aws waf get-sampled-requests --web-acl-id 4881aa42-de4a-4b6d-9792-63fc34a72946 --rule-id fec390cb-95f3-40cc-9549-5e85f1894f7f --time-window StartTime=2019-06-24T14:30,EndTime=2019-06-24T14:40 --max-items 10
{
  "TimeWindow": {
    "EndTime": 1561402967.702,
    "StartTime": 1561402800.0,
    "SampledRequests": [
      {
        "Action": "BLOCK",
        "Timestamp": 1561402929.913,
        "Request": {
          "Country": "BR",
          "URI": "/block.txt",
          "Headers": [
            {
              "Name": "Host",
              "Value": "nrt20.health.kurir.in",
            },
            {
              "Name": "User-Agent",
              "Value": "Amazon-Route53-Health-Check-Service (ref 622c4bdb-7a31-45ef-afbb-bd1d67696611; report http://amzn.to/lvsZADi)",
            },
            {
              "Name": "Accept",
              "Value": "*/*",
            },
            {
              "Name": "Accept-Encoding",
              "Value": ""
            },
            {
              "Name": "ClientIP",
              "Value": "54.232.40.97",
            },
            {
              "Name": "Method",
              "Value": "GET",
            },
            {
              "Name": "HTTPVersion",
              "Value": "HTTP/1.1",
            },
            {
              "Name": "Weight",
              "Value": 3
            }
          ]
        }
      }
    ]
  }
}
```

Source:
AWS Summit [7]
[8]

AWS Web Application Firewall Console with Report

WAF Console to view Incidents and DDoS Detected Report



Who can be affected by DDoS Attacks

Amazon Virtual Private Cloud (Amazon VPC)

Use security groups and network access control lists

EC2 Instances

Limit surface area exposed and use elastic IP address

Amazon Route 53 hosted zones

Take advantage of specialized always-on DNS protection

AWS Global Accelerator

Use multiple regions to minimize latency and maximize availability

Classic/Network/Application Load Balancers

Build to easily scale up and scale out

Amazon API Gateways and Amazon CloudFront distributions

Use AWS WAF to build custom rules or deploy partner rules

Source:
AWS Summit [7]
[8]

AWS Identity and Access Management (IAM)

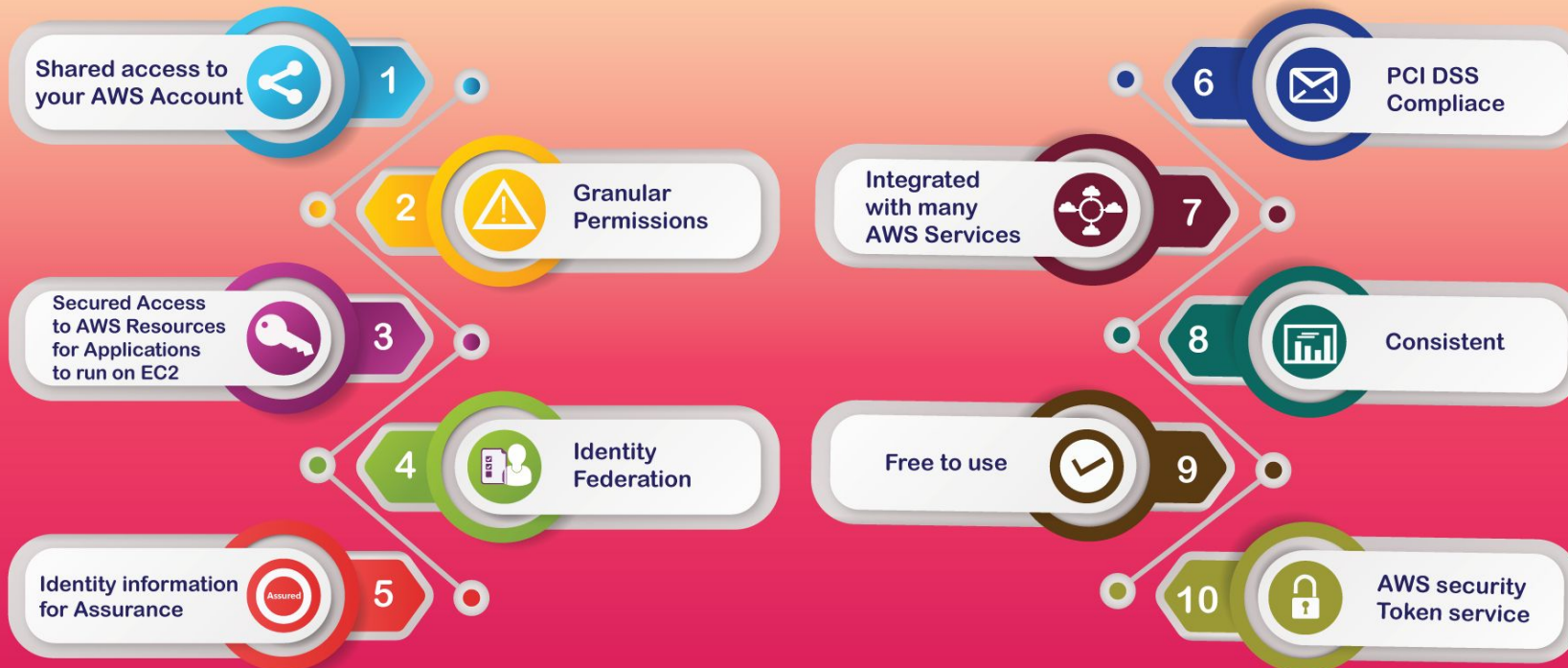
- IAM or Identity Access Management is a web service that allows AWS users to securely control access to resources
- IAM is used to control who is signed in(authorized) and has permissions(authorized) to use AWS resources

Features of IAM - 1

- **Shared access:** Administrators can provide others with access and permissions to Amazon resources without needing to share their password or access key
- **Granular control:** Administrators can provide different permissions to different users based on needs and security standards
- **Added Security to Amazon EC2 Applications:** IAM features can be used to provide credentials for applications running on EC2 instances. These credentials allow the app to access other Amazon resources, such as DynamoDB tables
- **Multi-factor authentication:** Two factor authentication, such as a password and authenticator code, can be added to an account and individual users for added security
- **PCI DSS Compliance:** Supports the processing, storage, and transmission of credit card data; the service has been validated as being compliant with the Payment Card Industry Data Security Standard
- **Amazon Services Intergration**
- **High Availability:** IAM data is replicated across multiple servers within Amazon's datacenters around the world
- **Free to Use**

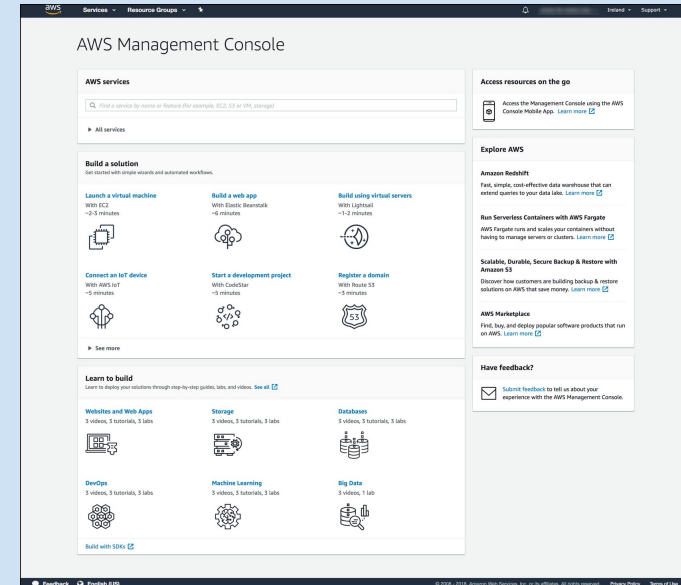
Features of IAM - 2

FEATURES OF AWS IDENTITY AND ACCESS MANAGEMENT?



Features of IAM - 3

- Amazon Web Services Management Console
- Amazon Command Line Tools
- Amazon SDKs
- IAM HTTPS API



Amazon Chime SDK

Embed proven real-time communication capabilities in your apps



Client SDKs

Embed in client-side application to initiate, control & terminate media sessions.



AWS SDK

Use Chime APIs in server-side application to create & manage media resources.



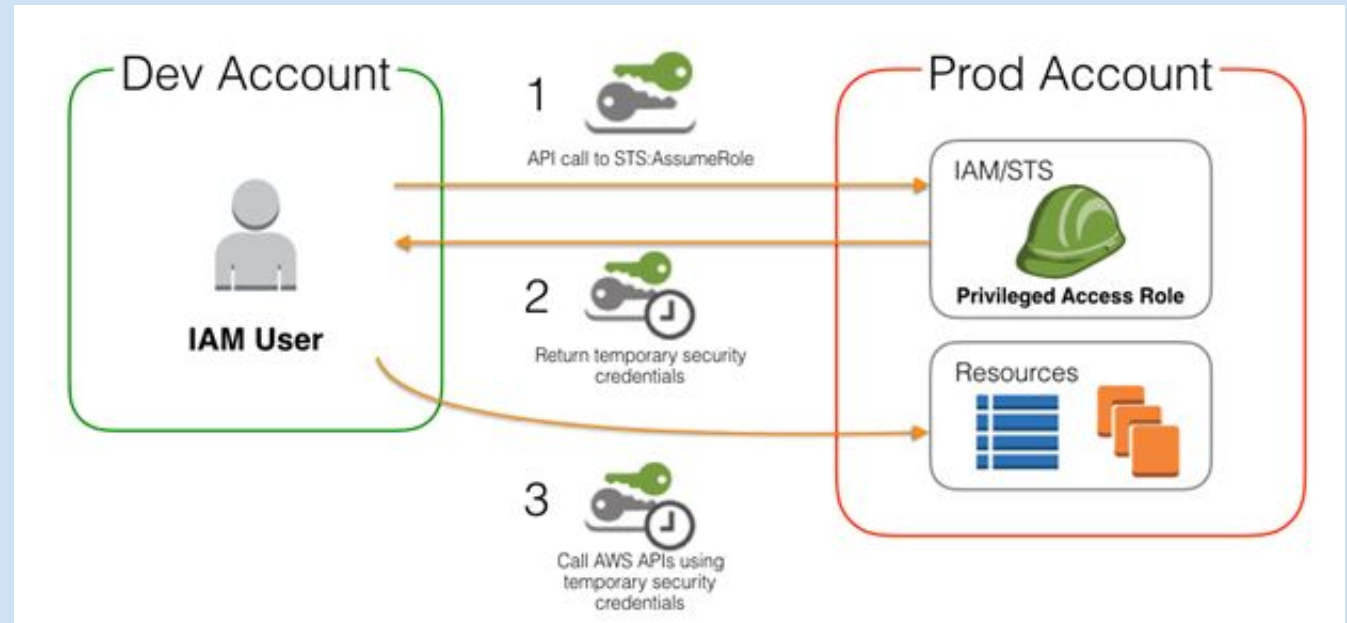
Media Services

Media sessions & services to support audio calling, video calling & screen sharing.

```
aws> ec2
ec2
ecs
inspector
codecommit
aws> ec2 descinst
describe-instances
describe-conversion-tasks
describe-instance-status
aws> ec2 describe-instances --mi
--max-items [integer]
```

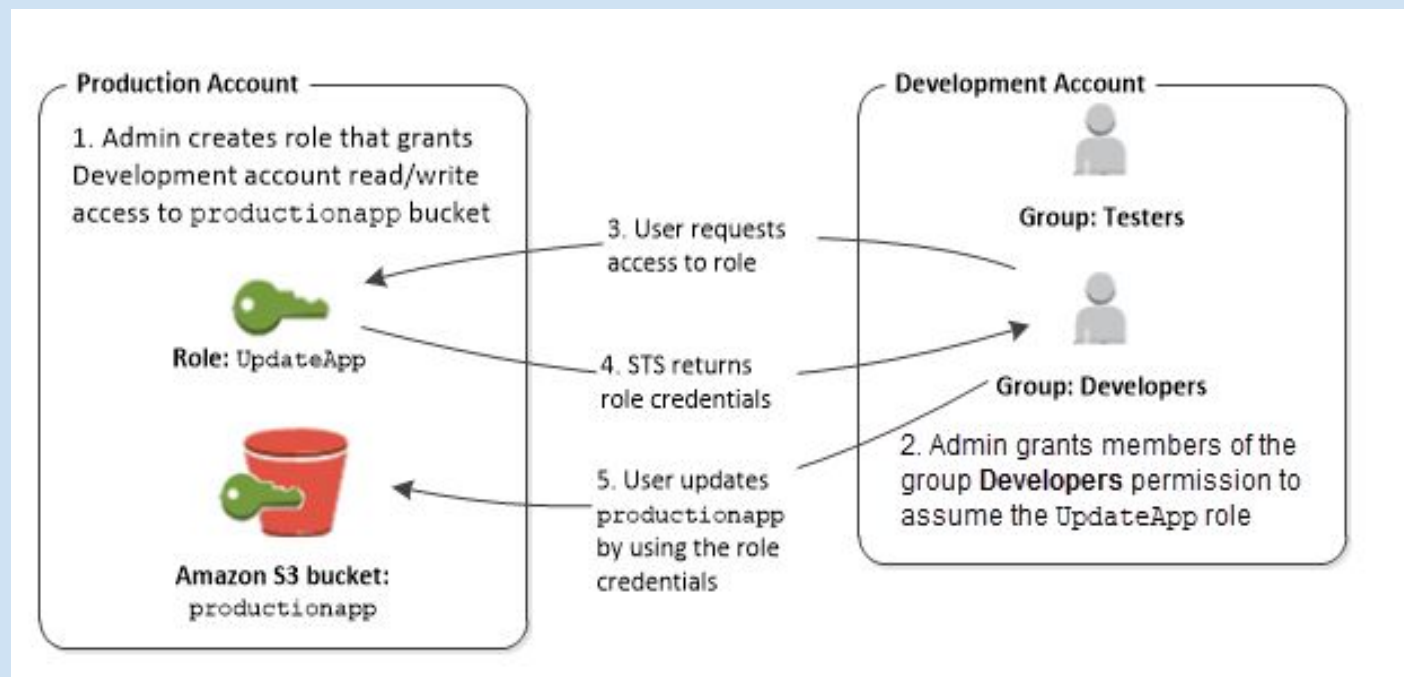
IAM Users

- An entity that you create in AWS to represent the person or application that uses it to interact with AWS. A user in AWS consists of a *name* and *credentials*
- Credentials include:
 - *Console Password*
 - *Access Keys*
 - *SSH Keys*
 - *Server Certificates*
- By default, a brand new IAM user created using the AWS CLI or AWS API has no credentials of any kind. The admin must create the type of credentials for an IAM user based on the needs of your user



IAM Role

- An IAM identity that you can create in your account that has specific permissions
- Similarly to IAM users, it is an identity with permission policies that determine what the identity can or cannot do in AWS
- Unlike users, which are assigned to a single entity, roles can be assumed on a need basis by multiple users
- Temporary security credentials based on assigned roles are also provided during a role session, meaning role users do not need long-term credentials for access

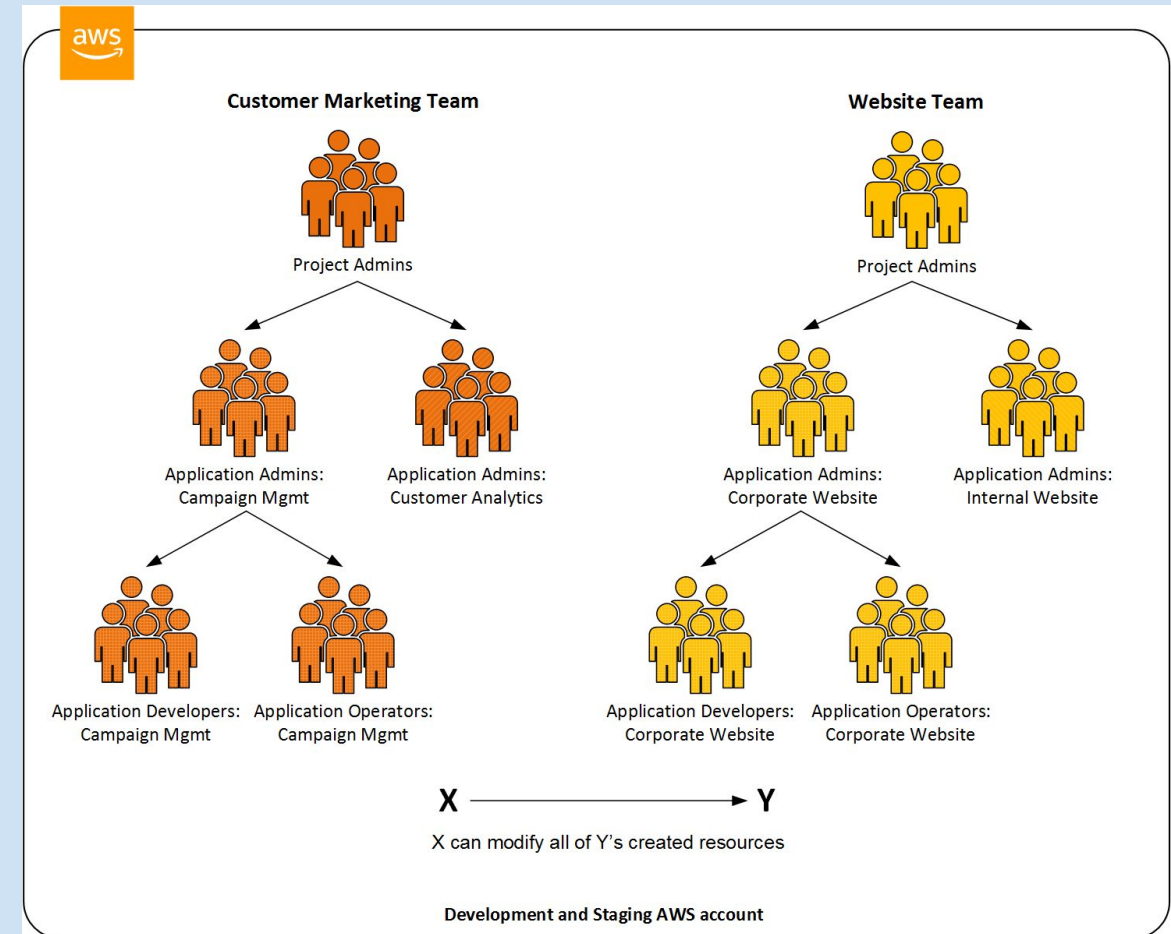


How IAM Works

- **Principal**
- **Requests**
- **Authentication**
- **Authorization**
- **Actions or Operations**

IAM Principal

- The **Principal** is a person or application that can make a request for an action or operation on an Amazon resources
- The Principal is authenticated as an AWS account root user or IAM entity
- As a security precaution, do NOT use root user credentials for daily work such as IAM operations. Instead, create IAM entities(users and roles)
- Federated users and Programmatic access is also supported to allow an application access to an Amazon account



IAM Requests

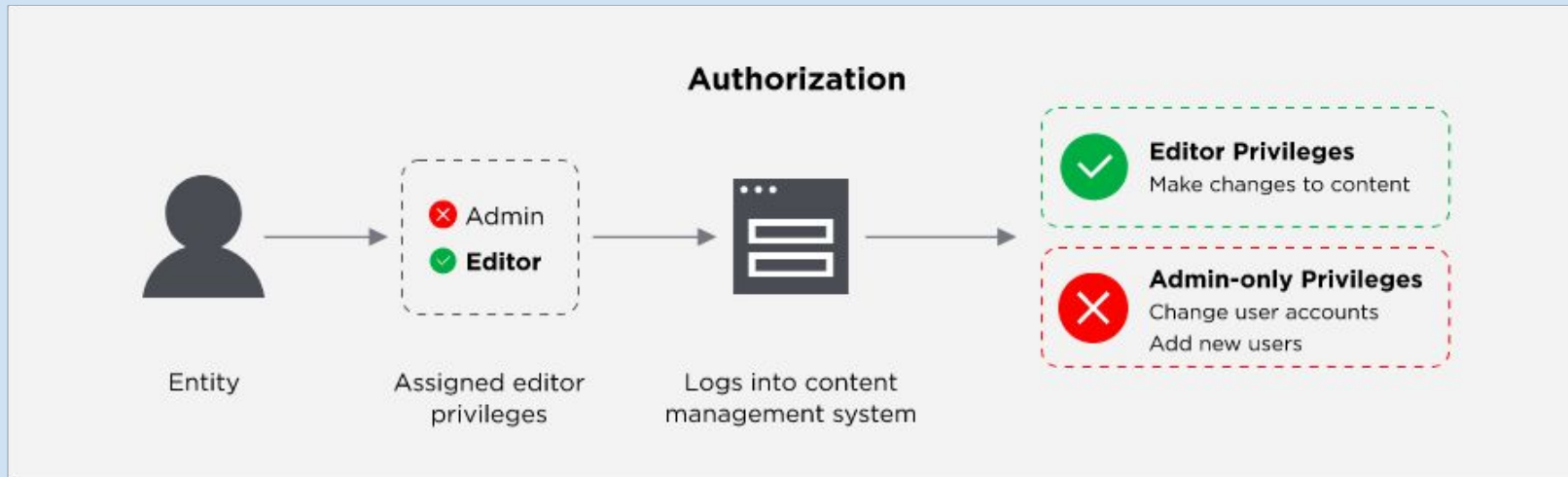
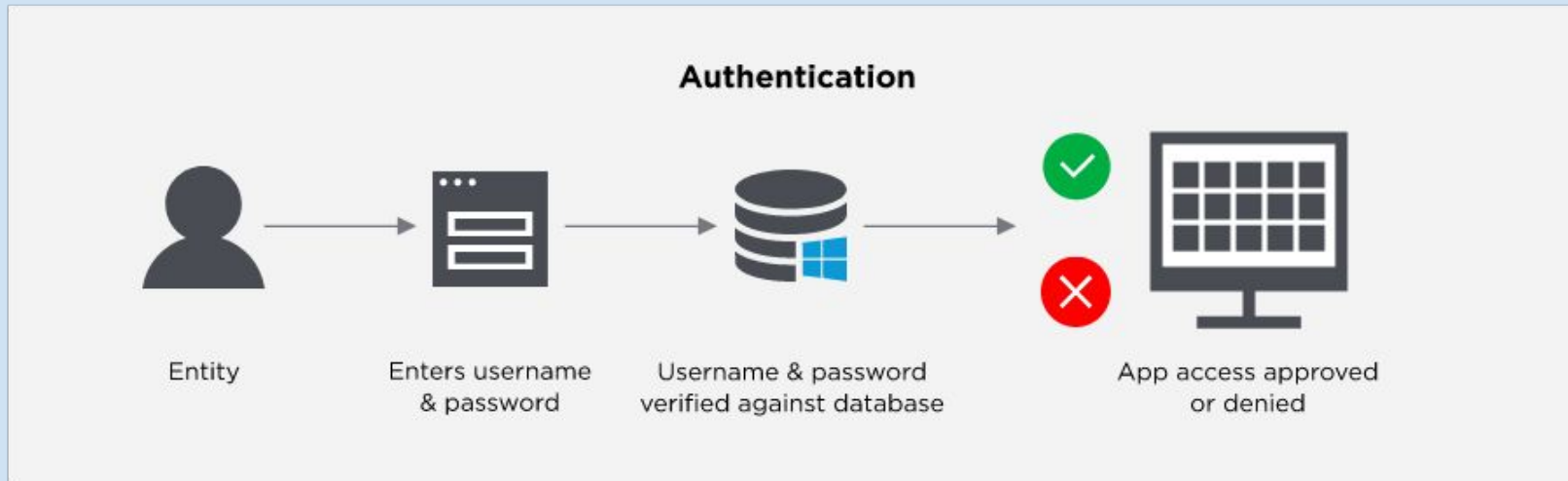
When a principal tries to use the AWS Management Console, Amazon API or CLI, that principal sends a request with the following information to Amazon, which is then stored as *request context* used to evaluate and authorize the request:

- **Actions or Operations:** actions in the AWS Management Console or operations in the Amazon CLI or API, that the principal wishes to perform
- **Resources:** The AWS resource object acted on
- **Principal:** Information such as policies associated with the entity used to sign in
- **Environmental data:** IP address, user agent, SSL enabled status, timestamps
- **Resource data:** Data relevant to the resource being requested; e.g. Dynamo DB table names, Amazon EC2 tags

IAM Authentication & Authorization

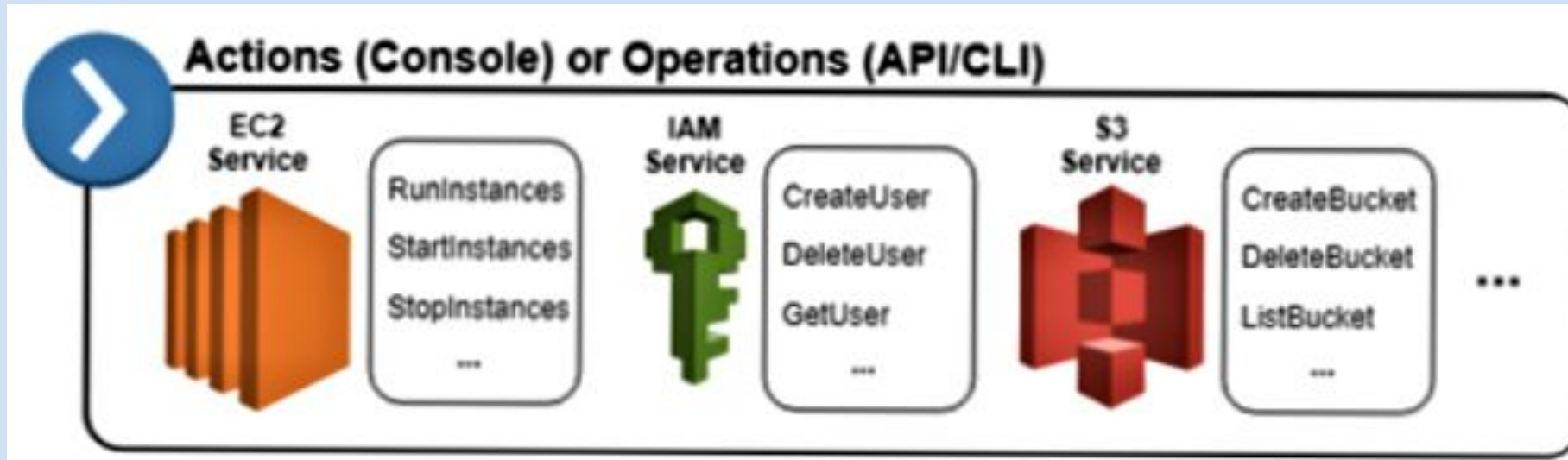
- Principals in general must be **authenticated**(by signing in to AWS) to send a request to AWS
 - **Using the console(root user)**: email and password
 - **API or CLI**: access key and secret key
 - Multi-factor authentication is also recommended by Amazon to increase security
-
- During **authorization**, AWS uses the *request context* to check policies related to the request
 - These policies(JSON file) determine whether a request should be allowed or denied
 - *Explicit deny* is enforced
 - If any single permissions policy includes a denied action, AWS denies the entire request(AWS root user request are almost always allowed by default)
 - By default, all requests are denied
 - A *explicit allow* in a permissions policy overrides this default

IAM Authentication & Authorization



AAA Actions or Operations

- After authentication and authorization, AWS allows for the **action** or **operation** in the request
- Operations are based on the nature of the service, and typically involve *viewing, creating, editing or deleting* that resource



AWS Database Protection using Snowball Edge

Snowball protects user data when government users are importing or exporting data into Amazon S3, when user create a job, and when user device is updated.

1. Database Protection

Encryption for AWS Snowball Edge

AWS Key Management Service in AWS Snowball Edge

2. AWS Data Protection

Amazon Macie

AWS KMS

AWS CloudHSM

AWS Certificate Manager

AWS Snowball Family



AWS Snowball

- 80 TB capacity/10 G network
- Data encryption end-to-end
- Rugged 8.5 G impact case
- Rain and dust resistant



AWS Snowball Edge

- 100 TB capacity/10 Gb network
- Data encryption end-to-end
- Rugged 8.5 G impact case
- Rain and dust resistant
- Compute and storage for hybrid/edge workloads
- Rack-mountable, clusterable



AWS Snowmobile

- Exabyte-scale 45ft container
- Data encryption end-to-end
- Dedicated security personnel
- GPS tracking, alarm monitoring, 24/7 surveillance, and optional additional security

Encryption for AWS Snowball Edge

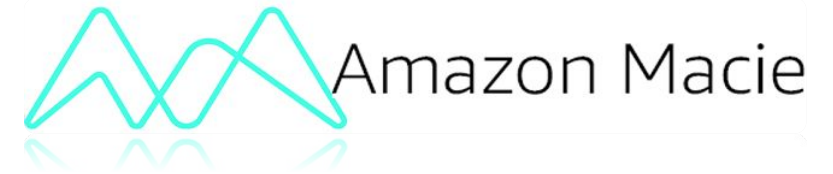
Data are protected over the network by SSL encryption when transfer all data to S3 through Snowball Edge.

1. To protect data at rest, AWS Snowball Edge uses server side-encryption (SSE).
2. AWS Snowball Edge supports server-side encryption with Amazon S3–managed encryption keys (SSE-S3). Server-side encryption is about protecting data at rest.
3. SSE-S3 has strong, multifactor encryption to protect your data at rest in Amazon S3.



By using SSL encryption and server side –encryption (SSE), data will have high security level and less likely being attacked.

Amazon Macie



Amazon Macie is Machine Learning powered visibility service identifies sensitive information to help automate security and compliance. There are two may purpose

1. Understand the data: Use Natural Language Processing (NLP) method to understand what the data is.
2. Understand data access: Machine Learning method to predictive user's behavior.

Approach

- Classify content
- Monitor and analyze access policies to content (IAM & ACL policies)
- Monitor and alert on unusual user behavior

Goal

- Categorize new or unknown threats
- High coverage (volume of true positives)
- High accuracy (few false positives)

Amazon KMS



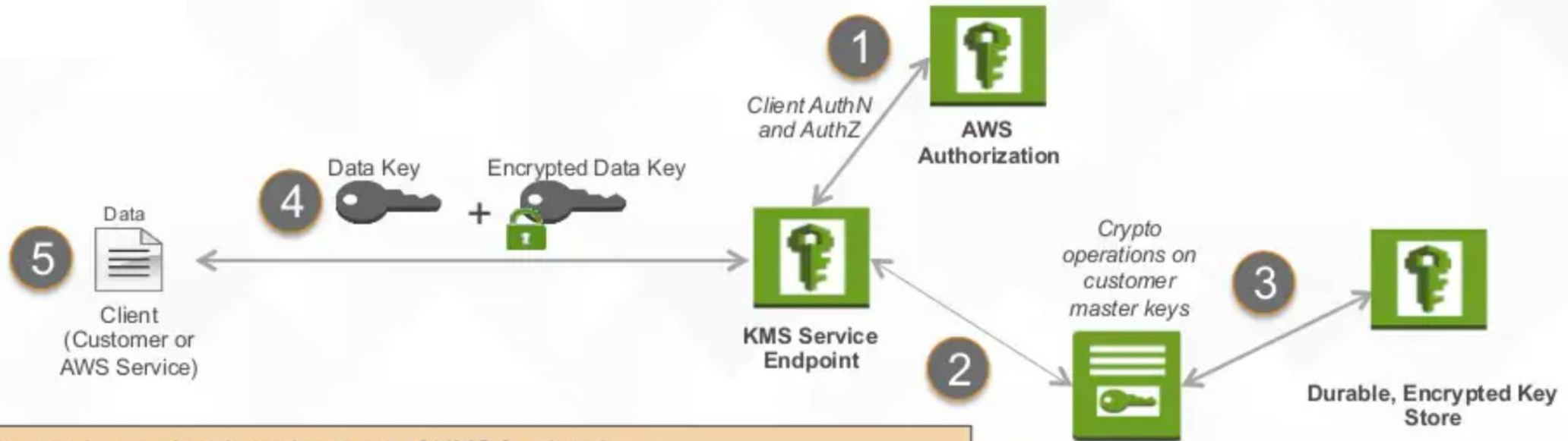
AWS KMS

1. A service that enables you to provision and use encryption keys to protect your data
2. Allows you to create, use and manage encryption keys from within your own application via AWS SDK and other AWS services (S3, EBS, RDS, Redshift)
3. Available in all commercial regions.

The AWS key Management Service (AWS KMS) is a managed service that makes it easy for users to create and control the encryption keys used to encrypt data.

- ❑ Customer Master keys (CMK): This is a key-encrypting key, basically KMS manages CMK.
- ❑ Data Key: This is generated by KMS via API. The API returns plaintext and encrypted version of data key.
- ❑ Permission Control: Users can define a resource-based policy

AWS Key Management Service



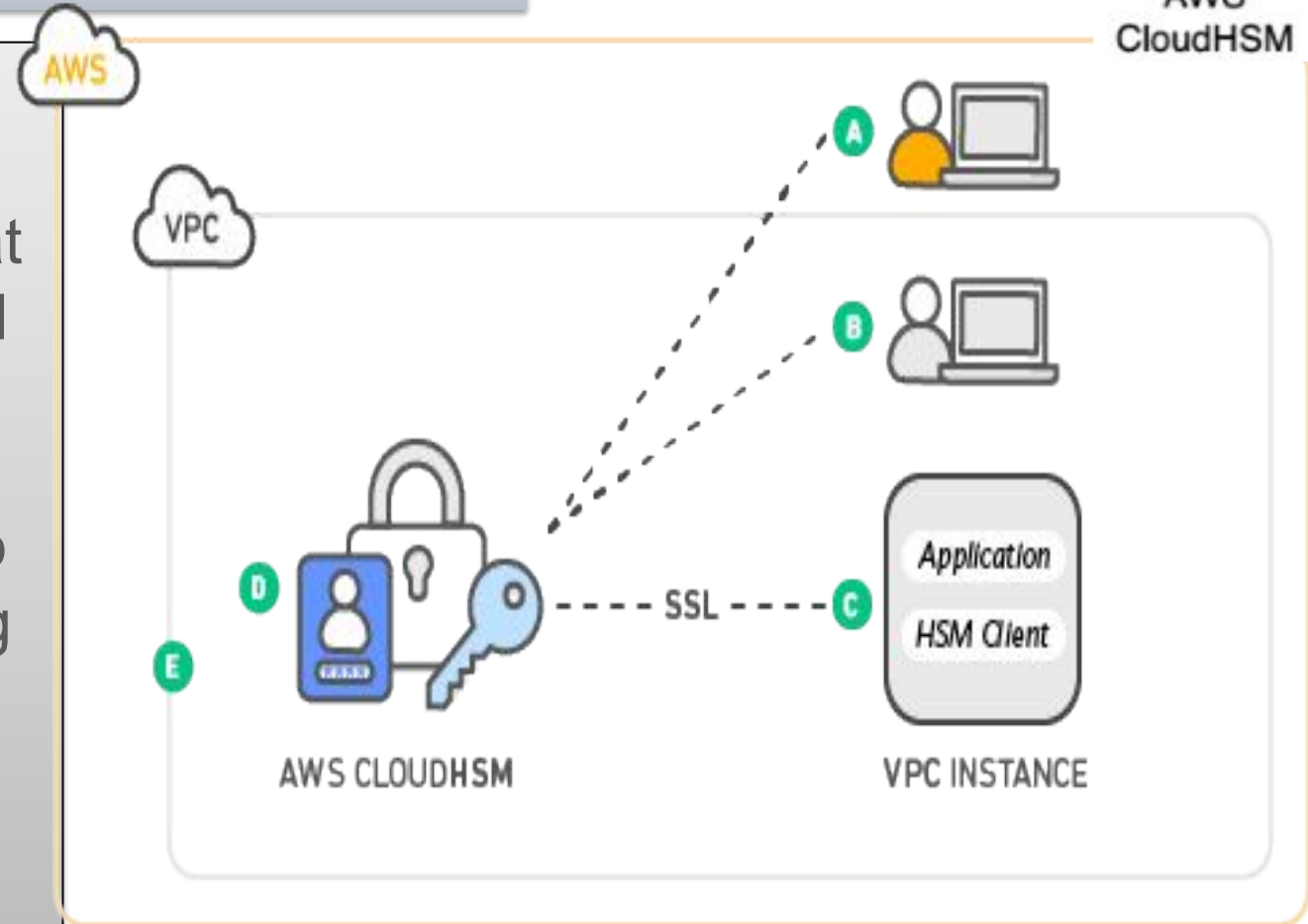
1. Client makes authenticated request of KMS for data key
2. KMS generates data key
3. KMS pulls encrypted customer master key from durable storage; decrypts in the KMS crypto module
4. KMS encrypts data key with named customer master key and returns plaintext data key and encrypted data key
5. Client uses data key to encrypt data, stores encrypted data key.

To decrypt: client submits encrypted data key to KMS for decryption; data key is needed to decrypt data



AWS CloudHSM

1. AWS CloudHSM is a cloud-based hardware security module (HSM) that enables users to easily generate and use their own encryption keys on the AWS Cloud.
2. CloudHSM offers you the flexibility to integrate with your applications using industry-standard APIs, such as PKCS#11, Java Cryptography Extensions (JCE), and Microsoft CryptoNG (CNG) libraries.



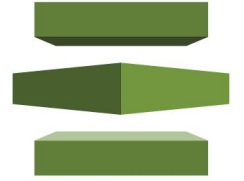
Difference between CloudHSM and KMS

AWS CloudHSM:

- Single-tenant HSM
- Customer-managed durability and availability
- Customer managed root of trust
- FIPS 140-2 Validation
- Broad third-party app support
- Symmetric and asymmetric ops
- High fixed price (\$16.5k/year/HSM)

AWS KMS:

- Multi-tenant AWS service
- Highly available and durable key storage and management
- AWS managed root of trust
- Extensive auditing
- Broad support for AWS services
- Symmetric encryption only
- Usage-based pricing



AWS Certificate Manager

1. AWS Certificate Manager is a service that lets you easily provision, manage, and deploy public and private SSL/TLS certificates for use with AWS services and internal connected resources.
2. With AWS Certificate Manager, Users can quickly request a certificate, deploy it on ACM-integrated AWS resources, such as Elastic Load Balancers, etc.

Highlights:

- Free public certificates for ACM-integrated services
- Managed certificate renewal
- Get certificates easily
- AWS certificate manager can protect and secure the website by provide an easy way to provision and manage these certificate
- Can also protect and secure user's internal resources
- Help users meet compliance requirements

AWS Threat Hunting and Detection

Threat purpose class

- **Backdoor**: resource compromised and capable of contacting source home
- **Behavior**: activity that differs from established baseline
- **Cryptocurrency**: detected software associated with cryptocurrencies
- **Pentest**: activity detected similar to that generated by known penetration testing tools
- **Persistence**: established a presence in the environment
- **Recon**: attack scoping vulnerabilities by probing ports, listening, using database tables, etc.
- **Resource consumption**: activity that differs from established baseline
- **Stealth**: attack trying to hide actions/tracks
- **Trojan**: program detected carrying out suspicious activity
- **Unauthorized access**: suspicious activity/pattern by unauthorized user

- All threats are placed into different threat purpose classes to determine the type of threat
- Different threats have different levels of severeness
- Government has their own set of threat classes

Threat Detection Classes

Reconnaissance

- Port scan
- Tor traffic
- Unprotected port probe
- User permissions

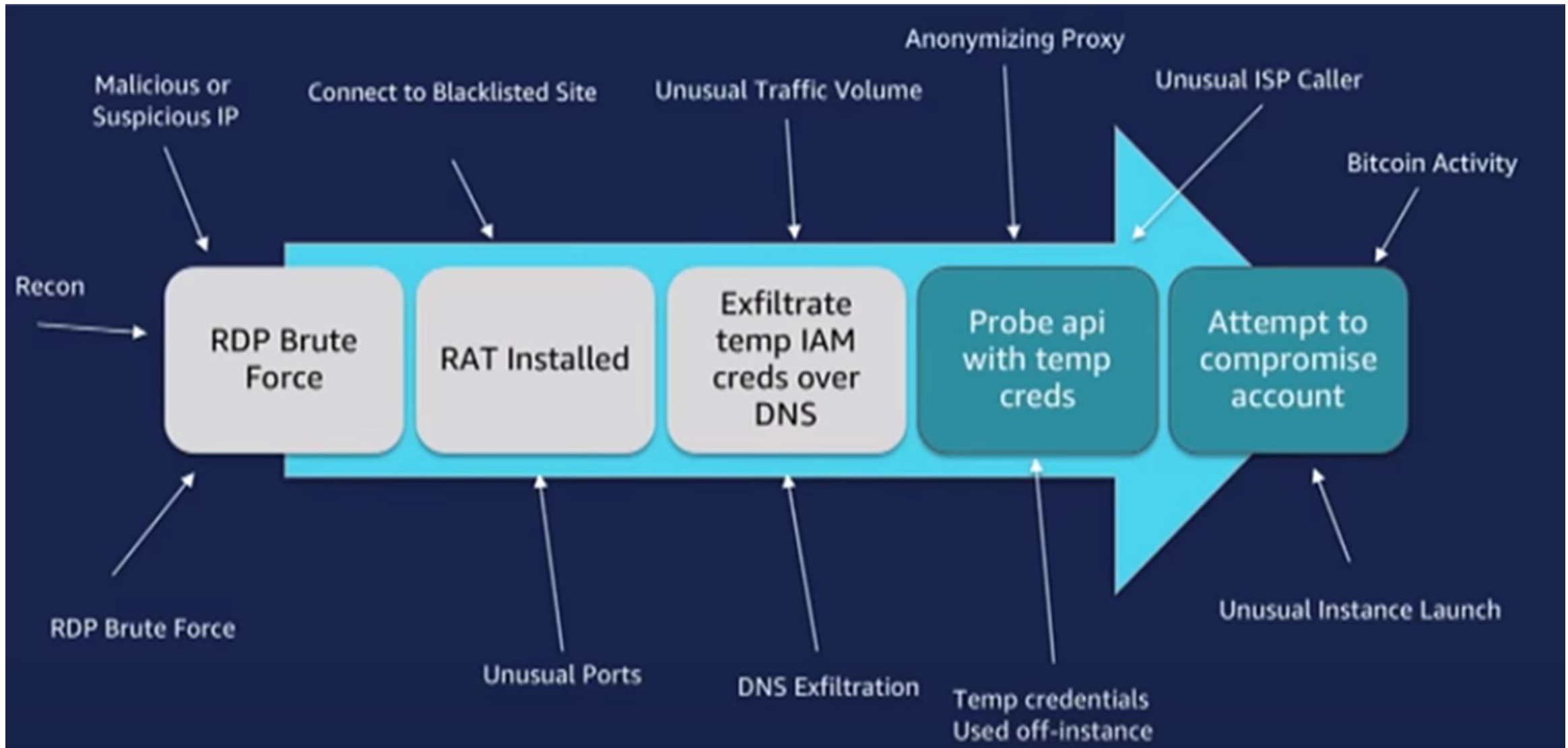
Instance Compromise

- Spam
- Unusual traffic volume
- DOS activity
- Data exfiltration

Account compromise

- Network permission changes
- Resource permission change
- Password policy change
- AWS CloudTrail logging disabled

AWS Roadmap to Detect Various Threats

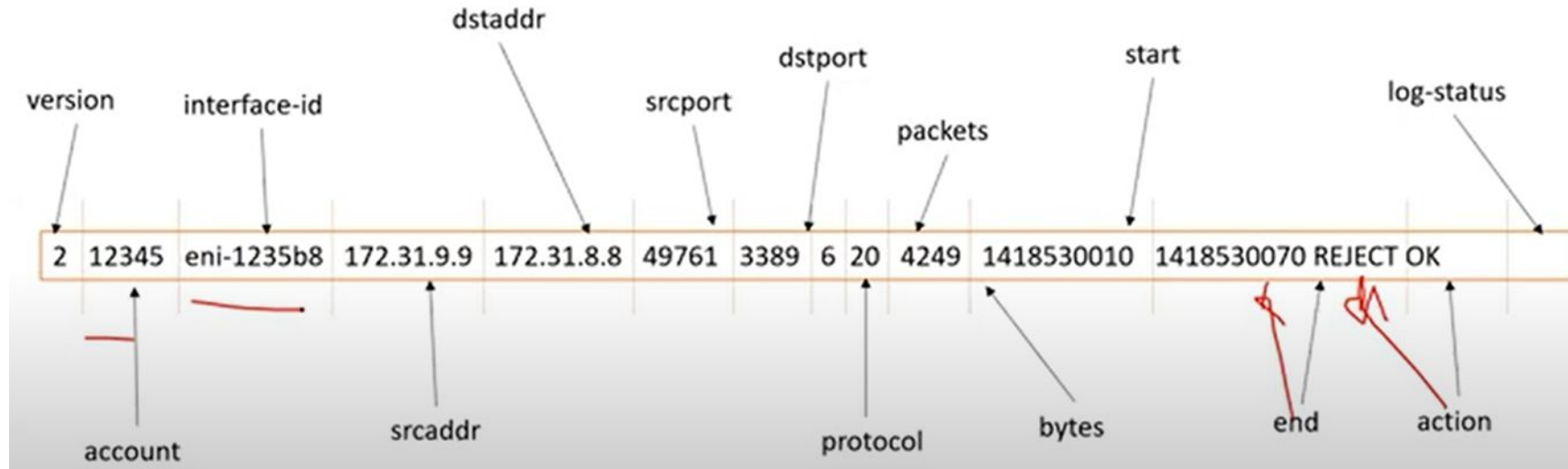


AWS Brute Force: Cloud Trail for Threat Hunting

CloudTrail lets you retrieve most API calls.

- Some API calls are not tracked, but not all: Trusted Advisor, Workspaces, Artifact, DeepComposer, DeepLense, etc.
- CloudTrail stores API calls for 90 day.
- CloudTrail can be configured to store API calls to S3 buckets
- The data is stored in JSON format for each extraction, translation, manipulation by standard tooling
- The CloudTrail logs are also accessible by querying the AWS API, just like interacting with any AWS service

AWS: Cloud Trail with VPC Flowlogs



S3 Bucket:

- Objects are compressed in gzip
- Each gzip file contains all flow logs collected from the aggregate interval period.
- Hard to analyze, easy to archive.

CloudWatch:

- Each log flows into CloudWatch individually
- CloudWatch provides filtering and display tools
- CloudWatch is great for building metrics/rules, not so great for archiving

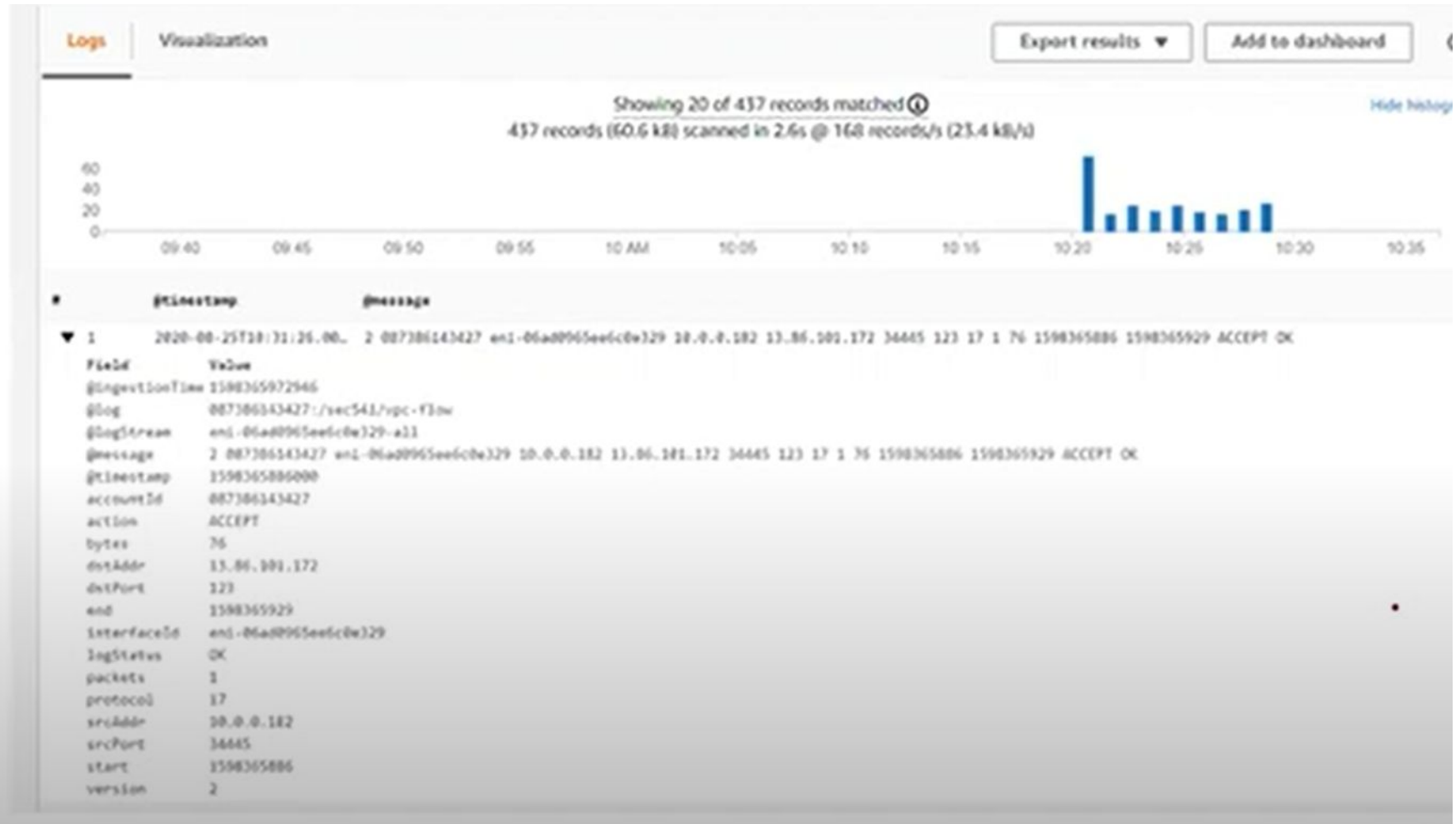
AWS Cloud Watch and Probe

Insights will detect log properties for AWS Log type

- VPC Flow Logs
- CloudTrail Logs
- Lambda
- Route53

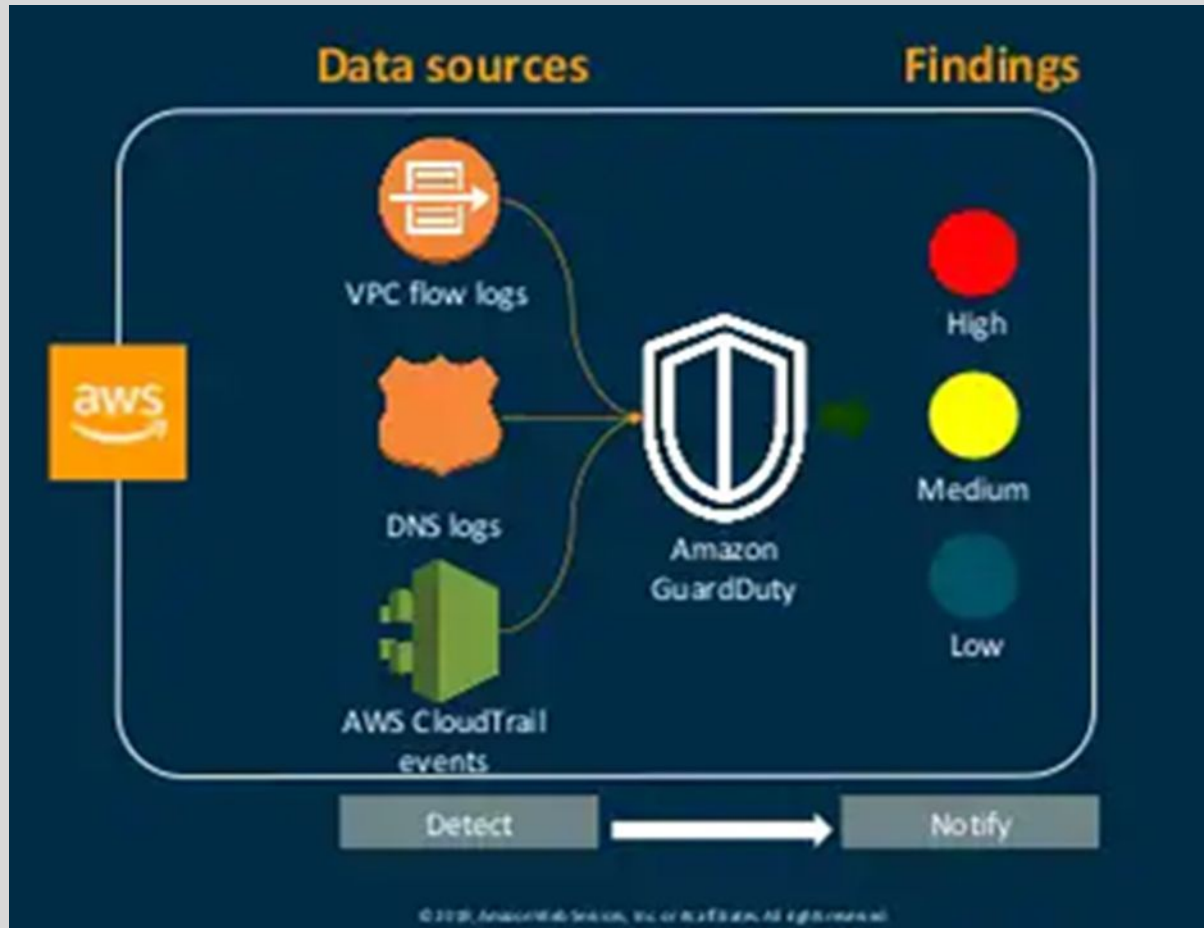
It will also auto detect JSON data.

The PARSE command can be used to parse up the



AWS GuardDuty: Threat Detection and Notification

Identify -> Protect -> Detect -> Respond -> Recover



- VPC logs don't need to be enabled to produce findings
- VPC flow logs will find information regarding network communications dealing with threat intel and behavioral detections
- DNS logs are set from queries via Amazon EC2 instances to known and unknown domains
- AWS CloudTrail identifies user and account activities, to include IP addresses, also stores a history of API calls

AWS GuardDuty: review threat findings

- Amazon GuardDuty aggregates all changes to findings that take place in five-minute intervals into a single event
- Amazon CloudWatch Events can be graphed, stored, exported, and further analyzed

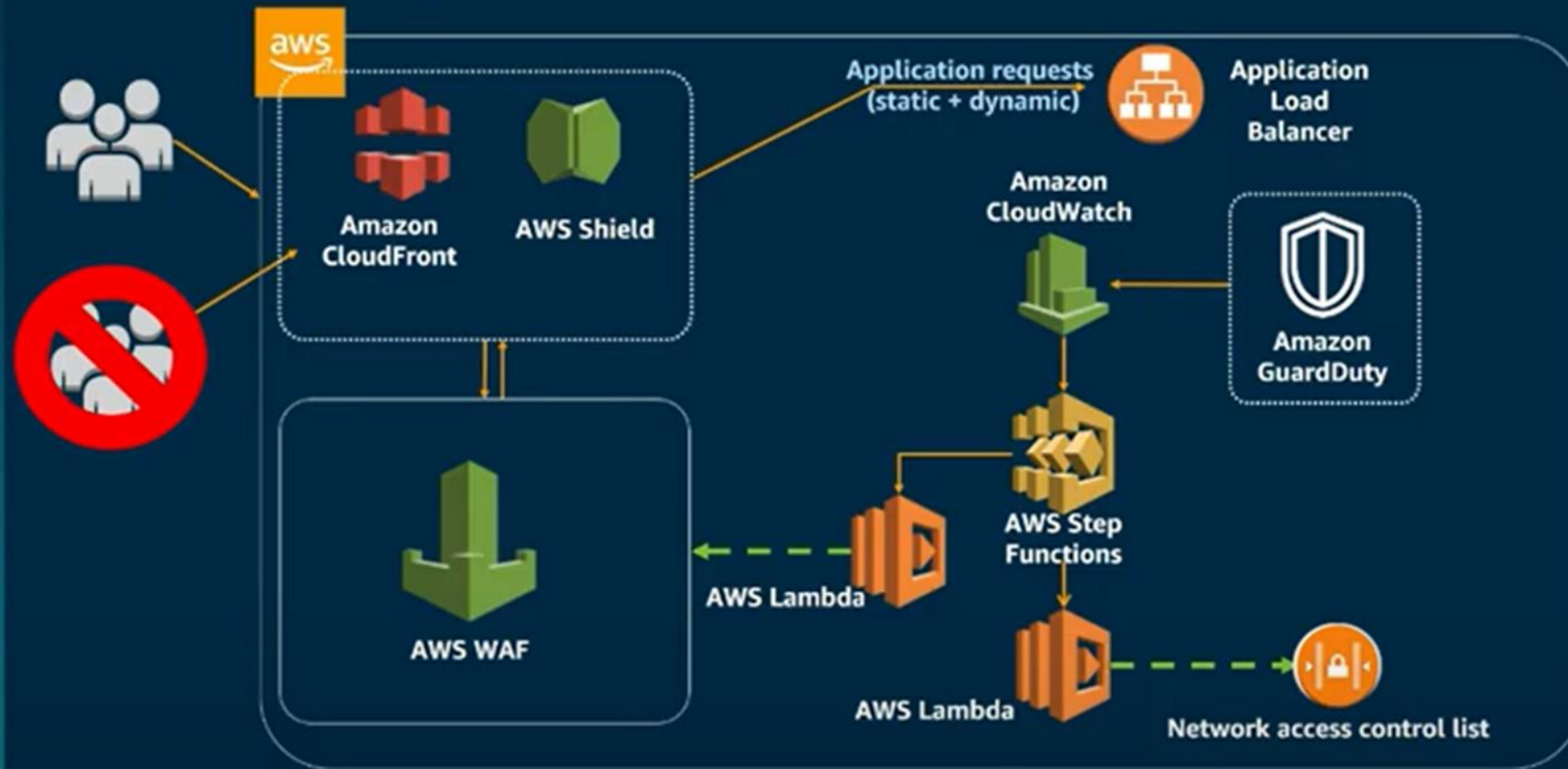
```
{
  "version": "0",
  "id": "cd2d702e-ab31-411b-9344-793ce56b1bc7",
  "detail-type": "GuardDuty Finding",
  "source": "aws.guardduty",
  "account": "111122223333",
  "time": "1970-01-01T00:00:00Z",
  "region": "us-east-1",
  "resources": [],
  "detail": {COMPLETE_GUARDDUTY_FINDING_JSON}
}
```

Example GuardDuty-related CloudWatch event

Source:
AWS Summit [7]
[8]

AWS GuardDuty: Incident Response

Incident response: Network ACL and AWS WAF rules



Future of Cloud Security and Challenges

1. Must support 3 classification levels — Unclassified, Secret and Top Secret.
2. Integrate cross-domain solutions to support inter-agency command, control and operations.
3. Cloud coalitions and the dynamic threat.
4. The integration of blockchain into cloud architecture.

References:

1. Federal Cloud Security, Katy Warren, MITRE , December, 2015.
2. Cloud Security in Government Today, www.govloop.com, June.2021.
3. How Government Agencies Meet Security and Compliance Requirements with the Cloud, Shawn P. McCarthy Adelaide O'Brien, September 2020.
4. Nutanix Clusters on AWS GovCloud supports Public Sector Cloud Smart Strategy, Alexander Ervik Johnsen, May 2021.
5. Migrating to AWS: Best Practices and Strategies, Stephen Orban, Head of Enterprise Strategy at AWS, April 2021.,
6. Accelerating AWS Journey: Migration & Modernization eBook, AWS, June 2021.
7. AWS Documentations: [Introduction to AWS Security: AWS Whitepaper](#)
8. [Cloud Security, Identity, and Compliance Products – Amazon Web Services \(AWS\)](#)